

ICT Risk Governance Requirements

Financial entities shall maintain documented ICT risk management procedures.

The procedures shall:

- identify critical ICT systems;
- define ownership responsibilities;
- establish annual risk reviews;
- maintain evidence of risk assessments;
- document incident escalation procedures.

Third-Party ICT Providers

Financial entities shall:

- review critical ICT vendors at least annually;
- maintain evidence of vendor assessments;
- define responsible owners for vendor oversight;
- establish escalation procedures for unresolved vendor risks.

Incident Management

Financial entities shall:

- maintain documented incident response procedures;
- conduct annual incident-response testing;
- preserve evidence of testing activities;
- document post-incident reviews.